LKY99 审计报告

智能合约安全审计报告
- 免责声明与保密声明
- 1. 项目概览
  - 1.1 审计范围
  - 1.2 审计简介
  - 1.3 项目背景
- 2. 审计总结
  - 2.1 漏洞统计
  - 2.2 审计结论
- 3. 技术与业务分析
  - 3.1 技术快速检查
  - 3.2 业务风险分析
- 4. 代码质量与安全性
  - 4.1 代码质量
  - 4.2 文档与可读性
  - 4.3 依赖使用
  - 4.4 中心化风险
- 5. 审计发现
  - 5.1 严重级别定义
  - 5.2 详细问题
  - Critical
  - High
- **Medium**
  - Low / Informational
- 6. 审计方法

智能合约安全审计报告

Prepared by: Audit911**Date:** 2026年4月20日

免责声明与保密声明

> **Audit911** 已基于行业最佳实践对目标合约进行分析，但审计不构成对合约“绝对安全”的保证。投资者/用户仍应自行完成尽调并承担决策风险。

---

1. 项目概览

1.1 审计范围

Item	Description
Project Name	LKY99
Website	N/A
Platform	BSC
Language	Solidity
Smart Contract Code	`0x28dA7cdEC01Eb82c66cBb37A17376De25e125231`
Commit Hash	N/A（链上合约）
Audit Date	2026-04-20

1.2 审计简介

本次审计目标是验证 LKY99 合约核心交易逻辑与资金流安全性，重点检查买卖税、AMM 交互、可重入风险、标准兼容性与可观测性问题，并对可利用性进行验证。

1.3 项目背景

LKY99 是一个带买卖税与分配逻辑的 ERC20 代币，部署于 BSC，并与 PancakeSwap V2 交易对进行流动性交互。合约包含：转账税分发、代币买卖封装函数及加池函数。

---

2. 审计总结

根据本次审计评估，目标合约整体安全性为 **安全** 。

2.1 漏洞统计

Severity	Count
Critical	0
High	0
Medium	0
Low	0
Informational	2

2.2 审计结论

未发现可直接“无权限盗走全部资产”的传统 Critical 漏洞，也未发现会造成用户资产损失的漏洞。

3. 技术与业务分析

3.1 技术快速检查

Main Category	Subcategory	Result
Contract Programming	Solidity version too old	Passed
	Integer overflow/underflow	Passed
	Function input parameters lack check	Passed
	Access control management	Passed
	Reentrancy / Race condition	Passed
Code Specification	Function visibility explicitly declared	Passed
	Unused code	Passed
Gas Optimization	"Out of Gas" Issue	Passed
	High consumption loops	Passed

3.2 业务风险分析

Category	Result
Buy/Sell Tax	当前链上观测：买入 3%，卖出 10%
Can Mint?	No（源码中存在 dailyMint 函数，但因 ownership 已转移至 dead 地址，当前已不可执行）
Blacklist Function?	No（未发现标准黑名单）
Honeypot Risk?	Potential（高税与到账偏离会形成强交易摩擦）
Anti-Whale/Bot?	Not Detected
Hidden Owner?	Not Detected
Can Take Ownership?	当前 ownership 如已转移至 dead 地址，不可再被有效转移

Category	Result
Auditor Confidence	Medium

4. 代码质量与安全性

4.1 代码质量

代码结构较直观，逻辑集中在 `_transfer`、`_distributeFees`、买卖与加池函数。

4.2 文档与可读性

代码注释基础可用。

4.3 依赖使用

合约主要通过接口调用 Pancake Router/Pair 与 USDT；未使用 `SafeERC20` 包装，存在返回值处理不一致问题。

4.4 中心化风险

源码设计上 owner 角色曾具备税率、分配地址、白名单、mint、claimToken 等管理权限；

但是当前链上owner 已转移至 dead 地址，则上述权限已不再具备现实可操作性。

5. 审计发现

5.1 严重级别定义

Level	Description
Critical	可直接导致资金被盗、资产永久损失或系统失控。
High	对交易安全或资产定价有重大影响，具备现实可利用性。
Medium	应尽快修复，可能在特定条件下造成损失或系统异常。
Low	标准兼容、工程实现或可观测性问题，影响较小。

5.2 详细问题

Critical

未发现 Critical 漏洞。

High

未发现 High 漏洞。

Medium

未发现 Medium 漏洞。

Low / Informational

`addLiquidityToPool` 直接改余额未完整发出 ERC20 `Transfer` 事件（Low）

Description: 用户入账与退款使用直接 `_balances` 修改，导致链上事件与真实余额变化不完全一致。

```
_balances[msg.sender] -= tokenAmount;
_balances[address(this)] += tokenAmount;
// 无 Transfer 事件
...
_balances[address(this)] -= unusedToken;
_balances[msg.sender] += unusedToken;
// 无 Transfer 事件
```

Recommendation: 涉及余额迁移时统一走 `_basicTransfer` 或补齐 `Transfer` 事件。
Status: Open

`claimToken` 未检查 ERC20 `transfer` 返回值（Low）

Description: 对非标准 ERC20 可能出现“转账失败但函数不回滚”的静默失败。

```
otherToken.transfer(owner, balance); // 返回值未检查
```

Recommendation: 使用 `require(otherToken.transfer(...), "...")` 或 `SafeERC20.safeTransfer`。
Status: Open

---

6. 审计方法

1. **Manual Code Review：** 对转账、税收分发、买卖/加池、增发与提取逻辑进行逐函数审查。
2. **Vulnerability Analysis：** 基于 AMM 结算模型分析交易公平性、价格影响与可利用路径。
3. **Automated Tools：** 使用 Slither 做静态检测，使用 Foundry Fork 测试做链上行为验证（PoC）。
4. **Reporting：** 对每个发现给出成因、影响、复现依据与修复建议。

© 2026 Audit911. All rights reserved.